

Cybersecurity Governance Framework

A Strategic Advisory for a Fintech Startup in Greece

Prepared by

Thelma Dziedzorm Avornyo

thelmaavornyo@gmail.com

ALT/SOE/025/3772

Executive Summary

This report presents a cybersecurity governance framework for a Greek fintech startup that has recently expanded into online payments. It addresses the organization's absence of formal governance which carries significant legal, financial, and reputational damage.

The framework addresses five critical dimensions: international standards alignment, stakeholder accountability, priority policy deployment, performance measurement, and executive engagement. Every recommendation has been calibrated to the organization's current size, Greek and EU regulatory obligations, and the elevated risk profile that accompanies online payment processing.

Operating an online payments platform involves high volume transactions and customer data. Without a framework, there will be an increase in compliance failures, cyberattacks, regulatory penalties and reputational risk.

Section 1: Cybersecurity Governance Framework & Standards

1.1 The Recommended Framework Architecture

This report recommends combining multiple cybersecurity frameworks rather than relying on a single standard. Each framework addresses different business and security risks, creating a stronger structure ready for regulatory compliance.

The Three Recommended Frameworks:

Risk Management Foundation: ISO/IEC 27001:2022

The Operational Guide: NIST Cybersecurity Framework 2.0

The Payment Security Requirement: PCI DSS v4.0

1.2 Relevance To Fintech

ISO/IEC 27001:2022 – The Risk Management Foundation

ISO 27001 establishes the foundational Information Security Management System (ISMS) and is the only certifiable standard recommended, which is critical for doing business with enterprise clients, payment processors, and potential investors. It is highly relevant for the fintech startup because it introduces stronger controls for cloud services, threat intelligence, and data masking, which are essential for an online payments environment.

The ISMS aligns the organization with both GDPR requirements under Greek Law 4624/2019 and the Digital Operational Resilience Act (DORA) regulation which is mandatory for financial entities across the EU.

The ISO 27001 certification strengthens the organization's credibility by showing that security risks are being managed effectively, which can improve customer confidence, build trust with regulators, banking partners and potential investors.

NIST CSF 2.0 — The Operational Guide

The NIST CSF 2.0 is recommended as the operational guide for the startup's cybersecurity activities. Unlike frameworks focused primarily on compliance, NIST CSF provides a practical structure for managing the day-to-day operations of the organization.

Its six core functions (Govern, Identify, Protect, Detect, Respond, Recover) help the organization build a security lifecycle that can be understood by both technical teams and business leadership. This makes it easier to align cybersecurity decisions with business objectives and risk management priorities.

The addition of the Govern function in NIST CSF 2.0 is particularly valuable for a growing fintech company because it ensures cybersecurity decisions align with business objectives.

PCI DSS v4.0 — The Payment Security Requirement

PCI DSS v4.0 is a mandatory security standard for organizations that process online card payments. Since the startup handles cardholder data, compliance is essential to reduce financial, operational, and reputational risk.

Given the startup's online payment operations, Self-Assessment Questionnaire – Type A for E-commerce Payments SAQ A-EP is likely the more appropriate PCI DSS compliance starting point because the organization's platform will likely interact with the payment environment, even if payment processing is outsourced to a third-party provider.

As the business grows, it should work toward a formal Qualified Security Assessor (QSA) assessment within 18 months to strengthen payment security governance, reduce breach liability, and maintain customer trust. Non-compliance carries fines of up to \$100,000 per month from card schemes, while a security breach while non-compliant transfers full liability to the organization.

Section 2: Roles & Responsibilities

2.1 Governance Structure Overview

Cybersecurity governance is a shared responsibility that must extend beyond the IT department. To ensure robust oversight, the following model establishes a hierarchy of shared accountability. This structure is specifically crafted to define clear roles and responsibilities, embedding security at every level of the organization.

Layer	Responsibility
Board / CEO	Strategic oversight, risk ownership, funding approval
CISO (Security & Compliance Lead)	Security programme management, risk reporting, governance oversight
CTO / IT Operations	Secure system design, technical controls, implementation of security measures
HR	Security awareness, onboarding, and training compliance
Legal / Compliance (including DPO function where applicable)	Regulatory monitoring, GDPR compliance, policy alignment
Employees	Day-to-day adherence to security policies and reporting of incidents

2.2 Key Roles

Chief Executive Officer (CEO)

The CEO is the ultimate risk owner who ensures that cybersecurity is treated as a strategic business priority. The CEO approves the risk appetite statement, signs off on the annual security budget, and acts as the public face of the organization when a significant incident occurs.

Chief Information Security Officer (CISO)

At the current company size, an outsourced CISO or senior manager is appropriate for this role. The CISO or Security & Compliance Lead oversees the security governance programme, maintains the ISMS, manages risk assessments, coordinates incident response planning, and reports security posture to executive leadership.

Chief Technology Officer (CTO)

The CTO ensures security is embedded within the technology environment. This includes secure APIs, implementation of development security operations, vulnerability management, and ensuring compliance with PCI DSS technical requirements.

Data Protection Officer (DPO)

Under GDPR Article 37, a DPO is mandatory for organizations that process personal data at scale so this applies to the fintech startup. The DPO ensures compliance with GDPR obligations, including

oversight of data protection impact assessments, handling data subject requests, maintaining processing records, and liaising with the Greek supervisory authority which is the Hellenic Data Protection Authority (HDPa) where necessary.

Department Heads & Team Leads

Department heads ensure security policies are enforced within their teams, training requirements are completed, and incidents are escalated appropriately. They act as operational extensions of the governance structure.

All Employees

As the primary target for attackers, the human element remains a critical factor in security. All employees must ensure adherence to security practices, protection of sensitive information, and timely reporting of threats to keep the fintech secure. Regular awareness training is also essential to prevent phishing and other social engineering attacks.

2.3 RACI Matrix – Governance Accountabilities

The following RACI matrix assigns Responsible (R), Accountable (A), Consulted (C), and Informed (I) designations across core governance activities.

Responsibility Area	CEO	CISO	CTO	DPO	Board
Framework Adoption & Budget Approval	A	R	C	C	I
Risk Register Maintenance	I	R	C	C	A
Incident Response Execution	I	R	R	C	I
GDPR Compliance & DPA Liaison	A	C	C	R	I
PCI DSS Compliance Programme	A	R	R	C	I
Security Awareness Training	I	R	C	C	I
Third-Party Risk Assessment	A	R	C	C	I
Policy Review & Approval	A	R	C	C	I
Board Security Reporting	R	A	C	C	R
Vulnerability Management	I	A	R	C	I

Legend: R = Responsible · A = Accountable · C = Consulted · I = Informed

Section 3: Priority Policies & Procedures (Year 1)

3.1 Selection Rationale

Trying to implement every possible security policy in the first year is a common mistake. It often results in surface-level governance that offers little protection to businesses. The three policies selected here focus on the most likely causes of serious incidents in a fintech startup: human error, unauthorized access, and data breaches. Each one maps to key regulatory requirements and addresses a known threat vector.

3.2 Policy 1: Information Security & Acceptable Use Policy (AUP)

Why it is Priority One

Globally, the leading causes of data breaches are social engineering and insider threats. An Acceptable Use Policy (AUP) addresses this by defining the expected behavioral standards for staff regarding the use of company data, systems, and devices. It includes enforcing of MFA and minimum of 12-character passwords. Without the AUP, the organization cannot enforce appropriate disciplinary action after a security incident, and is interpreted by regulators as a failure in corporate governance.

3.3 Policy 2: Access Control & Privileged Access Management (PAM) Policy

Why it is Priority Two

Unauthorized access to cardholder data, production environments, and administrative systems poses a severe threat in the payment industry. Since the theft of privileged credentials is a leading cause of major payment breaches, maintaining strict oversight is vital. This policy is required by ISO 27001 Control 5.15 and PCI DSS Requirement 7, which mandate formal access management to protect system components. This involves the principle of least privilege, role based access control (RBAC) and separation of duties. Beyond meeting regulatory standards, this policy serves as a security control against high-impact security failures.

3.4 Policy 3: Data Breach & Incident Response Plan

Why it is Priority Three

A security incident is inevitable rather than optional. What distinguishes a contained event from a major crisis is whether the organisation has a clear, documented, and regularly tested response process. Under GDPR Article 33, personal data breaches must be reported to the HDPA within 72 hours of discovery. Similarly, PCI DSS Requirement 12.10 requires a formal incident response capability. Without this policy in place, the organisation is forced to make critical decisions under pressure without a playbook, which significantly increases the likelihood of poor outcomes.

Section 4: KPIs or Measurement Framework

4.1 Why KPIs are Necessary

In order to manage risks effectively, there should be a reliable metric. The KPIs below provide a more accurate view of measuring overall governance effectiveness:

4.2 KPI Dashboard

KPI / Metric	Target	Measurement Frequency	Owner
PCI DSS Compliance Score	100% Req. met	Quarterly / Pre-audit	CISO
GDPR Breach Notifications (72hr)	100% on-time	Per incident	DPO
Critical Vulnerability Remediation	< 48 hours	Weekly	CTO
Security Awareness Training Completion	100%	Quarterly	CISO
Phishing Simulation Click Rate	< 5% of staff	Quarterly	CISO
MFA Adoption (Privileged Accounts)	100%	Monthly	CTO
Access Rights Review Completion	100% on schedule	Quarterly	CISO
Incident Response Drill Conducted	2x per year	Semi-annual	CISO
Mean Time to Detect (MTTD)	< 24 hours	Monthly	CTO
Mean Time to Respond (MTTR)	< 4 hours (P1)	Per incident	CISO
Third-Party Risk Assessments	100% of vendors	Annual	CISO

Section 5: Executive Buy-In & Ongoing Compliance

5.1 The Challenge: Why Governance Frameworks Fail

The most sophisticated security framework in the world fails if senior leadership treats it as an IT problem rather than a strategic issue. In a startup environment, where speed is celebrated and

process is often viewed as less important, cybersecurity governance faces some resistance. The strategies below are designed to make security governance commercially relevant.

5.2 Securing Executive Buy-In

The conversation with the CEO and Board should not begin with technical terms such as APIs, threats, vulnerabilities and firewall configurations. Rather the financial impact of cybersecurity risk should be quantified. This will include the estimated cost or fine for a PCI-DSS breach and GDPR data breach among others.

ISO 27001 certification and PCI DSS compliance are not just security controls. Enterprise customers and payment processors require evidence of security certification before entering commercial agreements. The CEO and board should be made to understand that the governance investment is also a revenue investment: it unlocks larger contracts and higher-value partnerships that would otherwise be unavailable to an uncertified startup.

In a nutshell, executives respond better when cybersecurity risks are connected to revenue impact, customer trust and business continuity.

5.3 Sustaining Ongoing Compliance

Compliance should not be seen as a one off or yearly activity but rather recurring. To ensure sustained ongoing compliance, the CISO must maintain a structured compliance programme to assist in implementing regular activities such as penetration testing, vulnerability reviews, policy assessments, security awareness training and annual PCI-DSS and ISO 27001 evaluations. To facilitate this process, the organization should incorporate automated reporting and monitoring tools.

Furthermore, there should be a strong security culture in the organization where employees of all levels are involved. For this framework to work, there should be clear channels for incident reporting and rewarding positive security behaviour. This will help reduce human related risks and improve accountability.

In addition, executive involvement is necessary to ensure ongoing compliance. To maintain their involvement, they should be provided with an annual security report highlighting the organization's risk posture, compliance status and major incidents in business language. This ensures cybersecurity remains visible at executive level and continues to receive the oversight necessary to support secure business growth.

Conclusion

As the organisation expands into online payments, cybersecurity governance can no longer operate as an informal function. The increasing volume of financial transactions and customer data requires a structured approach that aligns security with business growth and continuity.

The proposed framework provides a practical foundation by combining internationally recognised standards, clearly defined accountability, priority security policies, measurable performance indicators, and continuous compliance practices.

By aligning the framework with strategic impact and everyday operations, the organisation will be better positioned to operate effectively within the highly regulated fintech environment.
